

HR & PAYROLL MANAGEMENT PLATFORM

Sprint 1 MVP - Full-Stack Developer Handbook

Business Logic • Domain Model • API Contract • Database Rules • Security • Testing • Delivery

Reference organization: Software Solutions / Software Development Company

Changelog — v1.1

Adds real-time GPS capture on attendance check-in/check-out so employees can check in remotely from any location. See updated §2 (scope), §9 (Attendance Management — new §9.3/§9.4), §16 (Database), §17 (API), §18 (Security), §19 (Testing), and Appendix A. Policy: log-only, never blocks a check-in — see ADR-009 in the companion HLD v1.1.

Version 1.1 | August 2026 · Supersedes Version 1.0 (August 2026)

How to Use This Handbook

This handbook is intended to remain beside the codebase throughout Sprint 1. It defines the product boundary, business invariants, domain workflows, recommended data structures, API behavior, security requirements, test cases, and implementation sequence. When UI behavior and backend behavior disagree, the business rules in the domain/service layer should be treated as authoritative. The document intentionally separates current MVP rules from later extensions so that the first release stays deliverable.

- Use Sections 1-5 during product/domain design.
- Use Sections 6-14 while implementing each module.
- Use Sections 15-18 for database, API, security, and error handling.
- Use Sections 19-22 for testing, deployment, Definition of Done, and extension planning.
- Record deliberate deviations from this handbook as Architecture Decision Records (ADRs).

Contents

1. Product Vision and Company Profile
2. MVP Scope and Product Boundaries
3. Actors, Roles, Permissions and Tenant Model
4. Core Architecture and Engineering Principles
5. Domain Model and Data Ownership
6. Authentication and Account Lifecycle
7. Organization, Department and Position Management
8. Employee Management
9. Attendance Management v1.1
10. Leave Management
11. Overtime Management
12. Salary and Compensation Configuration
13. Payroll Engine
14. Payslip and Employee Self-Service
15. Dashboard, Notifications and Audit
16. Database Design and Integrity Rules v1.1
17. REST API Contract and Validation v1.1
18. Security, Privacy and Operational Controls v1.1
19. Testing Strategy and Critical Test Matrix v1.1
20. Sprint Backlog and Implementation Order
21. Definition of Done and Demo Script
22. Post-MVP Extension Roadmap
- Appendix A. Suggested Entities and Fields v1.1
- Appendix B. Status Machines
- Appendix C. Example Calculations
- Appendix D. Developer Checklists

1. Product Vision and Company Profile

The product is an internal HR and payroll management platform for a software solutions company that designs, develops, integrates, deploys, and supports customer-requested software. Sprint 1 must solve the company's essential workforce administration problems while establishing clean boundaries that can support a future commercial HR platform.

Category	MVP Assumption
Industry	Software Solutions / Software Development
Business Type	Custom software development and IT solutions provider
Services	Customer-desired web, mobile, enterprise, integration, and custom software
Workforce	Developers, QA Engineers, UI/UX Designers, Project Managers, DevOps Engineers, HR, Finance, Sales, Support
Payroll Currency	MMK by default
Timezone	Asia/Yangon by default
Payroll Cycle	Monthly
Work Model	Office, hybrid, remote-ready
Initial Product Model	Single organization in UX; organization-scoped architecture for future multi-tenancy

1.1 Business Objectives

- Centralize employee master data and employment status.
- Provide employee self-service for attendance, leave, OT, and payslips — from wherever the employee is working.
- Give HR controlled approval and correction workflows.
- Calculate monthly payroll from authoritative approved inputs.
- Protect salary and personally identifiable information (including location data) with strict authorization.
- Preserve historical payroll as immutable snapshots.
- Make future modules additive rather than requiring a rewrite of the core.

1.2 Success Metric for Sprint 1

The MVP is successful when an HR Admin can onboard an employee, the employee can record attendance (optionally from a remote location with GPS captured) and submit leave/OT, HR can approve those requests, payroll can be calculated for a month, and the employee can view the resulting payslip - with authorization, auditability, validation, and automated tests covering the critical rules.

2. MVP Scope and Product Boundaries

Module	Sprint 1 Capability	Priority
Authentication	Login, logout/session, password reset, protected routes	Critical
Organization	Company profile and operating defaults, incl. location capture toggle	Critical
Departments / Positions	Create, update, list, deactivate	High
Employees	Onboard, view, edit, search, deactivate	Critical
Attendance	Check-in/out with optional real-time GPS capture, history, HR correction	Critical
Leave	Types, balances, request, approve/reject/cancel	Critical
Overtime	Request, approve/reject/cancel	High
Salary	Basic salary, fixed earnings/deductions, OT settings	Critical
Payroll	Monthly run, calculate, approve, mark paid	Critical
Payslip	Employee-visible salary statement	Critical
Dashboard	Operational cards and pending work	Medium
Audit	Sensitive action history	Critical

2.1 Non-goals

- Recruitment/ATS and candidate pipeline.
- KPI, goals, performance appraisal, LMS.
- Assets and expense claims.
- Biometric devices, facial recognition.
- Hard geofence enforcement (rejecting a check-in by location) — **v1.1** log-only GPS capture is now in scope; see §9.3/§9.4.
- Complex shift rostering and multiple daily sessions.
- Direct bank disbursement.
- Full Myanmar PIT/SSB automation unless explicitly added after legal/accounting validation.
- AI agent and natural-language actions.

2.2 Scope Control Rule

A feature belongs in Sprint 1 only if it is required to complete the employee-to-payslip workflow, enforce its security/integrity, or operate the system reliably. Nice-to-have UI refinements and integrations should not displace critical domain correctness.

v1.1 scope change: GPS/geofencing was a non-goal in Version 1.0. Real-time, non-blocking GPS capture on attendance is now in scope per explicit product decision, because it directly supports the stated remote-work business objective (§1.1) without displacing critical domain correctness — it adds an optional field to an existing transaction rather than a new workflow.

3. Actors, Roles, Permissions and Tenant Model

Role	Responsibilities	Sensitive Access
Super Admin	Platform/organization setup, privileged support	Organization configuration; should not automatically expose payroll unless policy grants it
HR Admin	Employees, attendance correction, leave/OT approval, salary, payroll	Salary and payroll access; employee GPS location history
Employee	Own profile, attendance, requests, payslips	Own records only

3.1 Permission Matrix

Capability	Super Admin	HR Admin	Employee
Organization settings	R/W	R	-
Department/Position	R/W	R/W	R
Employee directory	R/W	R/W	Limited
Salary profile	Policy	R/W	Own limited
Attendance	All	All + correct	Own
Attendance location (GPS) v1.1	All	All (own org)	Own only
Leave/OT	All	Approve/manage	Own submit/view
Payroll	Policy	R/W/approve/pay	Own payslip only
Audit logs	R	R as permitted	-

3.2 Tenant Invariant

Every query and mutation must be scoped to the authenticated organization. Organization scope is derived from trusted authentication context. A client-provided organizationId must never be sufficient authorization. Cross-organization access returns not found or forbidden according to the chosen information-disclosure policy.

4. Core Architecture and Engineering Principles

A modular monolith is recommended for Sprint 1: one deployable backend with clear domain modules. This keeps deployment simple while preserving boundaries that can later be extracted if scale or organizational needs justify it.

```
Web Client (React/TypeScript)
  | REST/JSON
API Layer -> Auth/RBAC -> Domain Services -> Repositories -> PostgreSQL
  |
  +-> Audit / Notifications
```

4.1 Recommended Stack

Layer	Recommendation
Frontend	React + TypeScript + Vite
UI	Tailwind CSS or component library
Server state	TanStack Query
Forms	React Hook Form + Zod
Backend	Node.js + Express + TypeScript
Database	PostgreSQL
ORM	Prisma or equivalent
API docs	OpenAPI/Swagger
Testing	Vitest/Jest + Supertest + frontend component/E2E tools
Deployment	Docker + CI/CD
Geolocation v1.1	Browser Geolocation API (navigator.geolocation), requested on user action, not on page load

4.2 Layer Responsibilities

- Controller: HTTP parsing, authentication context, response mapping.
- Validator: request shape and primitive constraints.
- Service/domain: business rules, authorization decisions, state transitions, transaction orchestration.
- Repository: persistence only; no UI-specific business behavior.
- Frontend: user experience and optimistic feedback, never the sole enforcement point.

4.3 Money and Time

- Use decimal/fixed-precision database types for money; never IEEE floating-point for payroll.
- Define an explicit rounding rule and apply it consistently.
- Store timestamps in UTC where practical; interpret work dates in Asia/Yangon organization timezone.
- A payroll period is a business date range, not merely a timestamp range.

5. Domain Model and Data Ownership

```
Organization
|- Departments / Positions
|- Users -> Employee
|   |- AttendanceRecords (+ optional GPS metadata)
|   |- LeaveBalances -> LeaveRequests
|   |- OvertimeRequests
|   |- SalaryProfiles
|- PayrollRuns -> PayrollItems -> Payslips
|- AuditLogs / Notifications
```

5.1 Aggregate/Ownership Rules

- Organization owns all master and transactional data.
- User owns authentication identity; Employee owns employment data.
- PayrollRun owns PayrollItems for a specific period.
- PayrollItem is a historical snapshot and must not depend on mutable current salary values for display.
- LeaveBalance changes occur through controlled operations, not arbitrary field edits.

6. Authentication and Account Lifecycle

Rule	Requirement
AUTH-01	Only active accounts may authenticate.
AUTH-02	Passwords are stored using a strong one-way hash such as Argon2id or bcrypt.
AUTH-03	Reset tokens are single-use, random, hashed at rest where practical, and expire.
AUTH-04	Protected endpoints authorize every request server-side.
AUTH-05	Role/permission changes invalidate or rapidly cease old privileges.
AUTH-06	Login/reset endpoints are rate-limited.

6.1 Account Flow

1. HR creates employee and login identity or invites the employee.
2. Account starts in an activation state according to product policy.
3. Employee establishes password securely.
4. Login establishes authenticated session/token context containing stable user and organization identity.
5. Inactive/terminated employment may trigger account disablement according to policy.

6.2 Session Choice

Use either secure server sessions or short-lived access tokens with controlled refresh. If JWT is used, keep access tokens short-lived, protect refresh tokens, rotate where appropriate, and do not treat token claims as permanently valid after privilege changes.

7. Organization, Department and Position Management

Rule	Requirement
ORG-01	Name is required.
ORG-02	Default currency = MMK; timezone = Asia/Yangon; payroll cycle = monthly.
ORG-03	Currency changes after payroll history exists are blocked or handled through a future migration workflow.
ORG-04 v1.1	Organization has a <code>locationCaptureEnabled</code> flag (default true) governing whether GPS coordinates submitted with attendance are stored.
DEPT-01	Department name is unique within organization among active records.
POS-01	Position belongs to organization and may be linked to department.
MASTER-01	Referenced departments/positions are deactivated instead of hard-deleted.

7.1 Suggested Departments

- Engineering
- Quality Assurance
- UI/UX Design
- Project Management
- DevOps / Infrastructure
- Human Resources
- Finance
- Sales / Business Development
- Customer / Technical Support

8. Employee Management

8.1 Employee Lifecycle

DRAFT -> ACTIVE -> INACTIVE / TERMINATED

Rule	Requirement
EMP-01	Employee number is unique within organization.
EMP-02	Join date is required before activation.
EMP-03	Department and position must be active and organization-scoped.
EMP-04	Salary is excluded from ordinary directory payloads unless caller has payroll permission.
EMP-05	An employee with transactional history cannot be hard-deleted.
EMP-06	Termination prevents new attendance/leave/OT after effective end date.

8.2 Suggested Profile Groups

- Identity: employee code, legal/display name, work email, phone.
- Employment: join date, department, position, manager, employment type, status.
- Work: office/hybrid/remote work model.
- Payroll: salary profile reference; bank data deferred or tightly restricted.
- System: linked user account, created/updated/audit fields.

9. Attendance Management

Sprint 1 supports one primary work session per employee per organization workday. Multiple shifts, breaks, and biometric devices are deferred. Real-time GPS capture on check-in/check-out is supported so employees can check in from any location — see §9.3. v1.1

Rule	Requirement
ATT-01	Only active employees can check in.
ATT-02	A second check-in while an open session exists is rejected with conflict.
ATT-03	Check-out requires an open session.
ATT-04	Check-out must be later than check-in.
ATT-05	Working minutes are calculated server-side.
ATT-06	HR correction requires reason, actor and audit record.
ATT-07	Approved full-day leave prevents an employee being classified absent for that day.
ATT-08	Work date is derived in organization timezone.
ATT-09 v1.1	Client may optionally submit GPS coordinates (<code>lat</code> , <code>lng</code> , <code>accuracyMeters</code>) with check-in and check-out.
ATT-10 v1.1	Missing, denied, or failed GPS capture never blocks or delays check-in/check-out; <code>locationSource</code> is recorded as UNAVAILABLE.
ATT-11 v1.1	Location is never used to reject, delay, or flag a check-in/check-out as invalid in Sprint 1 — no radius or geofence check runs in the request path.
ATT-12 v1.1	When the organization's <code>locationCaptureEnabled</code> is false, the server discards any coordinates the client sends and persists none.
ATT-13 v1.1	Raw GPS coordinates are visible only to HR Admin, Super Admin, and the owning employee; excluded from bulk employee directory/export payloads.

9.1 Derived Status

MVP statuses may include PRESENT, ABSENT, LEAVE, LATE, and INCOMPLETE. Only enable LATE when a work-start policy exists. Avoid storing a status that can become inconsistent with source facts unless the status is intentionally snapshotted.

9.2 Edge Cases

- Open session crossing midnight: either disallow in MVP or assign to check-in work date with a maximum duration guard.
- Clock correction: HR cannot create negative duration.
- Approved leave and attendance on same date: preserve both facts and define reporting precedence.
- Remote work: treated the same as office attendance until location policy exists — superseded by §9.3 below (v1.1 adds optional location capture; remote work still never blocks or differs in workflow).
- v1.1 GPS accuracy worse than a configured threshold (e.g. >150m) is stored as-is and may show a "low accuracy" hint in the UI; it is never a rejection reason.
- v1.1 Client-supplied coordinates are not verifiable and must not be treated as proof of physical presence — document this as an accepted MVP limitation, not a security control.

9.3 Remote GPS Check-In v1.1

Objective: an employee can check in and check out from anywhere. HR gains visibility into where a check-in happened, without any legitimate check-in ever being blocked by location.

- Frontend requests `navigator.geolocation.getCurrentPosition` only when the employee taps Check In / Check Out — never on page load — with a short timeout (e.g. 5-8s) and a single retry at most.
- On success, send `{ lat, lng, accuracyMeters }` in the check-in/check-out request body.
- On denial, timeout, unsupported browser, or any geolocation error, submit the request with no location fields — the action proceeds identically to a manual check-in.
- Backend stores whatever was sent (subject to ATT-12) and sets `locationSource` to GPS or UNAVAILABLE accordingly. There is no MANUAL location-entry UI in Sprint 1 — MANUAL is reserved for a future HR-entered correction, not client input.
- The attendance detail view (HR) and self-service view (employee, own records only) may render the captured coordinates or a map pin; ordinary list/table views should not.

9.4 Location Data Handling v1.1

- Treat GPS fields as sensitive personal data, same tier as salary: minimize exposure, never include in bulk exports, never log raw coordinates in application logs beyond what's needed for debugging (and redact before shipping to any third-party logging service).
- Do not build any distance/geofence calculation into the check-in/check-out request path in Sprint 1 — see HLD v1.1 §11.4 and Appendix D for the deferred design if the organization later opts into enforcement.
- The `locationCaptureEnabled` organization setting is itself an audited field (organization policy change, per §15.4).

10. Leave Management

```
PENDING -> APPROVED
        -> REJECTED
        -> CANCELLED
APPROVED -> CANCELLED (controlled policy only)
```

Rule	Requirement
LEV-01	startDate <= endDate.
LEV-02	Requested duration is calculated server-side from working-day policy.
LEV-03	Overlapping pending/approved requests for the same employee are rejected.
LEV-04	Paid leave approval requires sufficient balance unless an authorized override exists.
LEV-05	Balance is consumed when status becomes APPROVED, not on submission.
LEV-06	Valid cancellation restores consumed balance exactly once.
LEV-07	Approval/rejection records actor, timestamp, comment.
LEV-08	Unpaid leave may be approved without paid balance and becomes a payroll input.

10.1 Initial Leave Types

- Annual Leave
- Sick Leave
- Casual Leave
- Unpaid Leave

10.2 Concurrency Requirement

Approval and balance consumption must occur atomically. Two simultaneous approval attempts must not double-deduct balance. Use a database transaction and an appropriate locking/version strategy.

11. Overtime Management

PENDING -> APPROVED | REJECTED | CANCELLED

Rule	Requirement
OT-01	Employee must be active for the OT date.
OT-02	endTime > startTime.
OT-03	Duration is derived server-side.
OT-04	Overlapping OT requests are rejected.
OT-05	Only APPROVED OT is payroll-eligible.
OT-06	OT included in an approved payroll cannot be silently edited.
OT-07	Payable amount uses a documented company rule and is snapshotted in payroll.

11.1 MVP OT Formula Options

Choose one explicit rule before coding. Example A: approved hours x employee OT hourly rate. Example B: derived hourly basic rate x company multiplier x approved hours. Do not hide the multiplier/divisor in source code; make it configuration with an effective date when feasible.

12. Salary and Compensation Configuration

SalaryProfile is the mutable current/future compensation configuration. PayrollItem is the immutable historical result. This distinction is critical.

Component	MVP Rule
Basic salary	Required, non-negative monthly amount
Fixed allowance	Named recurring earning
Fixed deduction	Named recurring deduction
OT rule/rate	Optional payroll input
Effective from	Required for controlled salary changes
Currency	MMK inherited from organization in MVP

- Salary changes require payroll privilege and audit logging.
- Use Decimal/NUMERIC, e.g. NUMERIC(18,2), or a deliberate integer minor-unit representation.
- Never update past PayrollItems when SalaryProfile changes.
- If effective dating is implemented, prevent ambiguous overlapping salary profiles for the same employee.

13. Payroll Engine

13.1 State Machine

DRAFT -> CALCULATED -> APPROVED -> PAID

Transition	Guard
Create -> DRAFT	Period valid; no conflicting run.
DRAFT -> CALCULATED	Eligible employees and salary inputs validated.
CALCULATED -> CALCULATED	Recalculation allowed before approval.
CALCULATED -> APPROVED	No blocking errors; authorized actor.
APPROVED -> PAID	Authorized actor confirms payment outside system.
APPROVED/PAID -> earlier state	Blocked in MVP; future reversal/adjustment workflow.

13.2 Calculation

Gross Pay = Basic Salary + Fixed Allowances + Approved OT + Bonus
Net Pay = Gross Pay - Fixed Deductions - Unpaid Leave Deduction - Other Authorized Deductions

13.3 Payroll Invariants

- One standard monthly payroll run per organization and period in MVP.
- Only eligible employees with applicable salary configuration are included.
- Only approved leave/OT source records affect payroll.
- Every PayrollItem stores snapshots of salary components and derived amounts.
- Recalculation is idempotent: it replaces/rebuilds calculated items safely and never duplicates them.
- APPROVED and PAID items are immutable.
- Negative net pay is blocked or explicitly flagged for manual resolution.
- Calculation results must be deterministic from stored inputs and configuration.
- Approval and item freezing occur transactionally.

13.4 Unpaid Leave Rule

Recommended MVP rule: daily basic rate = monthly basic salary / configured payroll working-day divisor; unpaid leave deduction = daily basic rate x approved unpaid leave days. The divisor is company policy and must be visible/configurable. If the company later adopts calendar-day or actual-working-day rules, version the policy.

13.5 Example

Item	Amount
------	--------

Basic Salary	1,000,000 MMK
Fixed Allowance	100,000 MMK
Approved OT	50,000 MMK
Gross	1,150,000 MMK
Fixed Deduction	20,000 MMK
Unpaid Leave	40,000 MMK
Net	1,090,000 MMK

14. Payslip and Employee Self-Service

- One payslip corresponds to one employee payroll item for one period.
- Employees can read only their own released payslips.
- Payslip values come exclusively from payroll snapshots.
- Minimum content: company, employee, employee code, period, basic salary, earning breakdown, deduction breakdown, gross and net pay.
- Recommended MVP release point: APPROVED. If policy requires PAID, make release status configurable later.
- PDF rendering is a presentation concern and must not recalculate payroll.

15. Dashboard, Notifications and Audit

15.1 HR Dashboard

Metric	Definition
Active Employees	Count of ACTIVE employees
Present Today	Valid attendance for today
On Leave	Approved leave covering today
Pending Leave	PENDING leave requests
Pending OT	PENDING OT requests
Current Payroll	Status of current monthly run
Payroll Cost	Clearly labeled gross or net aggregate

15.2 Employee Dashboard

- Today's attendance state and check-in/out action
- Leave balances
- Pending leave/OT requests
- Latest released payslip

15.3 Notifications

- Submission may notify approvers.
- Approval/rejection notifies requester.
- Notification delivery failure does not invalidate a committed HR transaction.
- Prefer an outbox/event approach if asynchronous infrastructure is introduced.

15.4 Audit

Audit sensitive changes such as salary updates, attendance corrections, approvals, payroll calculations/approvals/payment status, role changes, and organization policy changes (including `locationCaptureEnabled` toggles **v1.1**). Store actor, action, resource type/id, organization, timestamp, and safe before/after metadata. Never store passwords, tokens, or unnecessary secrets in audit payloads.

16. Database Design and Integrity Rules

Entity/Table	Key Constraints
organizations	PK; status; default timezone/currency/payroll_cycle; location_capture_enabled v1.1
users	unique login identity; org FK; role/status
departments	org FK; unique active name per org
positions	org FK; department optional; active flag
employees	org FK; unique employee code per org; user optional unique link
attendance_records	employee FK; work_date; open-session guard/unique policy; check_in_lat, check_in_lng, check_in_accuracy_m, check_out_lat, check_out_lng, check_out_accuracy_m, location_source v1.1 (all location columns nullable)
leave_types	org FK; paid flag
leave_balances	employee + leave_type + period unique
leave_requests	employee FK; dates; status; approver metadata
overtime_requests	employee FK; start/end; status
salary_profiles	employee FK; effective date/range
payroll_runs	org + period + type unique
payroll_items	run + employee unique; snapshot amounts
payslips	payroll_item unique
audit_logs	append-oriented actor/resource metadata

16.1 Transaction Boundaries

- Leave approval + balance deduction.
- Leave cancellation + balance restoration.
- Payroll recalculation item replacement.
- Payroll approval + freeze metadata.
- Critical master-data changes that update multiple dependent records.

16.2 Deletion Policy

Prefer deactivation/soft deletion for master data referenced by history. Transactional payroll and approval records should not be hard-deleted through ordinary application APIs.

16.3 Location Columns v1.1

Store `check_in_lat`/`check_in_lng` and `check_out_lat`/`check_out_lng` as `DOUBLE PRECISION` (or `NUMERIC` with sufficient scale), accuracy columns as `INTEGER` meters, and `location_source` as a small enum (`GPS`, `MANUAL`, `UNAVAILABLE`). All six columns are nullable — a row with no GPS data is the expected common case, not an error state. No new table is required for Sprint 1; a dedicated geofence-zone table is deferred (see §22 and HLD Appendix D).

17. REST API Contract and Validation

Domain	Representative Endpoints
Auth	POST /auth/login, /auth/logout, /auth/refresh, /auth/forgot-password, /auth/reset-password; GET /auth/me
Organization	GET/PATCH /organization (v1.1: PATCH accepts locationCaptureEnabled)
Departments	GET/POST /departments; GET/PATCH/DELETE(deactivate) /departments/:id
Positions	GET/POST /positions; PATCH/deactivate /positions/:id
Employees	GET/POST /employees; GET/PATCH /employees/:id; POST /employees/:id/deactivate
Attendance	POST /attendance/check-in; POST /attendance/check-out (both v1.1: optional body fields lat, lng, accuracyMeters); GET /attendance/me; GET /attendance; PATCH /attendance/:id/correction
Leave	GET /leave/types; GET /leave/balances/me; POST /leave/requests; GET /leave/requests; POST /leave/requests/:id/approve reject cancel
Overtime	POST /overtime/requests; GET /overtime/requests; POST /overtime/requests/:id/approve reject cancel
Salary	GET/PUT /employees/:id/salary-profile
Payroll	POST /payroll-runs; POST /payroll-runs/:id/calculate approve mark-paid; GET /payroll-runs/:id
Payslip	GET /payslips/me; GET /payslips/:id
Dashboard	GET /dashboard/hr; GET /dashboard/me

17.1 API Rules

- Validate path, query, and body input.
- Return stable machine-readable error codes in addition to human messages.
- Pagination is mandatory for employee/attendance/request lists.
- Filtering is server-side and organization-scoped.
- Do not expose internal stack traces.
- Use idempotency/uniqueness protection for operations vulnerable to double-click/retry, especially payroll creation and approvals.
- **v1.1** Validate lat/lng/accuracyMeters for shape only (numeric range: lat $\in$ [-90,90], lng $\in$ [-180,180]); an invalid or missing value is dropped from the record, it never fails the check-in/check-out request with a 4xx.

17.2 Error Semantics

HTTP	Use
400	Malformed/invalid input
401	Authentication required/invalid
403	Authenticated but not permitted
404	Resource not found in authorized scope
409	Business conflict: duplicate/open/overlap/invalid concurrent state

422	Optional semantic business-rule violation
500	Unexpected server failure with safe message

18. Security, Privacy and Operational Controls

- TLS in production.
- Secure cookies if cookie-based sessions; SameSite/CSRF protection as appropriate.
- Password hashing and reset-token protection.
- Rate limiting and brute-force protection.
- RBAC plus resource ownership checks.
- Organization scoping in every repository/service path.
- Sensitive field minimization and response DTOs.
- Parameterized ORM/database access and validation.
- Security headers and controlled CORS.
- Secrets outside source control.
- Backups and restore procedure before real payroll use.
- Structured logs with request correlation IDs, but no credentials/tokens.
- Dependency scanning and CI checks.
- Audit privileged actions.

18.1 Payroll Security

Treat payroll as a privileged subsystem. Ordinary HR directory access must not imply salary access. Consider a separate payroll permission even if Sprint 1 maps it to HR Admin. Require re-authorization or stronger controls for future bank disbursement.

18.2 Location Privacy v1.1

- Treat raw GPS coordinates as the same sensitivity tier as salary: role-scoped read access only (HR Admin, Super Admin, owning employee), excluded from bulk exports and ordinary directory/list DTOs.
- Client-supplied coordinates are unverifiable — never use them as an authentication factor, an access-control gate, or grounds for disciplinary action without corroboration.
- Give the organization a real off switch (`locationCaptureEnabled=false`) and honor it server-side even if the client still sends coordinates.
- Do not forward raw coordinates to third-party analytics, logging, or notification services.

19. Testing Strategy and Critical Test Matrix

19.1 Test Pyramid

- Unit tests: pure calculation and state-transition functions.
- Service tests: authorization, business rules, transactions.
- Repository/integration tests: constraints and query scoping against a real test database.
- API tests: authentication, validation, error contracts.
- Frontend tests: forms, permissions, critical views.
- E2E tests: employee-to-payslip golden path.

Area	Must-pass Case
Auth	Inactive account cannot login
Tenant	Org A cannot read Org B employee
Attendance	Second check-in with open session fails
Attendance	Check-out without open session fails
Attendance / GPS v1.1	Check-in succeeds identically with GPS granted, denied, or unsupported
Attendance / GPS v1.1	Employee cannot fetch another employee's raw coordinates
Attendance / GPS v1.1	locationCaptureEnabled=false persists no coordinates even if client sends them
Attendance / GPS v1.1	Out-of-range lat/lng is dropped, not rejected — check-in still succeeds
Leave	Overlapping request fails
Leave	Insufficient balance blocks approval
Leave	Concurrent approval cannot double-deduct
Leave	Cancellation restores once
OT	Invalid/overlapping interval fails
Payroll	Duplicate run for same period fails
Payroll	Recalculate does not duplicate items
Payroll	Approved run cannot recalculate
Payroll	Salary update does not change historical item
Payslip	Employee cannot fetch another employee payslip
Money	Rounding is deterministic at boundary values

20. Sprint Backlog and Implementation Order

Order	Epic	Exit Condition
1	Foundation	Repo, environments, lint/typecheck/test, DB migrations, CI
2	Auth + RBAC	Protected API and frontend route behavior
3	Organization master	Defaults and tenant context working
4	Departments/Positions	Master data CRUD/deactivation
5	Employees	Onboarding and lifecycle complete
6	Attendance	Check-in/out + optional GPS capture + HR history/correction
7	Leave	Types/balance/request/approval atomic
8	Overtime	Request/approval + payroll eligibility
9	Salary	Privileged compensation configuration
10	Payroll	Create/calculate/recalculate/approve/pay
11	Payslip	Own payslip display/release
12	Dashboards	Operational summaries
13	Hardening	Audit, security, integration/E2E tests, deployment

20.1 Suggested Story Slicing

Implement vertical slices. For example, Employee Create should include migration/model, repository, service rules, API validation, frontend form/list, permissions, and tests before moving to the next major workflow. Avoid building all database tables first and postponing integration until the end.

21. Definition of Done and Demo Script

21.1 Definition of Done

- Business rules implemented server-side and tested.
- Authorization and organization scoping verified.
- Database migration is reproducible.
- API documented and returns stable errors.
- Frontend handles loading, empty, success, validation, and failure states.
- Sensitive data is not leaked through list/detail DTOs.
- Audit exists for required privileged actions.
- No critical/high known defects in the golden path.
- Deployment from a clean environment succeeds.
- v1.1 GPS capture on check-in/check-out never blocks a legitimate check-in, and location is readable only by HR Admin, Super Admin, and the owning employee.

21.2 Golden-path Demo

1. HR logs in.
2. HR creates/uses Engineering department and Software Engineer position.
3. HR creates an employee and salary profile.
4. Employee activates/logs in.
5. Employee checks in (optionally from a remote location, with location permission granted) and later checks out.
6. Employee submits leave; HR approves.
7. Employee submits OT; HR approves.
8. HR creates the monthly payroll run.
9. System calculates payroll from salary and approved inputs.
10. HR reviews and approves payroll.
11. Employee views released payslip.
12. HR marks payroll paid.
13. Audit trail shows sensitive actions, including the attendance GPS capture.

22. Post-MVP Extension Roadmap

Phase	Extensions
Sprint 2 / HR Operations	Holiday calendar, shifts, richer leave accrual/carry-forward, half-day leave, multi-level approval, richer payroll components, validated Myanmar statutory rules, PDF payslips, reports, optional geofence enforcement (office-model radius check, org opt-in) v1.1
Sprint 3 / Talent	Recruitment/ATS, interview pipeline, onboarding, goals, KPI, appraisal
Sprint 4 / Operations	Expenses, assets, documents, announcements, advanced analytics, audit reporting
Sprint 5 / Automation	AI HR assistant, natural-language reporting, workflow assistance; always through authorization and domain services

Appendix A. Suggested Entities and Fields

Organization

id, name, status, timezone, currency, payrollCycle, payrollWorkingDayDivisor, **locationCaptureEnabled** v1.1, createdAt, updatedAt

User

id, organizationId, email, passwordHash, role, status, lastLoginAt, createdAt, updatedAt

Employee

id, organizationId, userId, employeeCode, fullName, phone, departmentId, positionId, managerId, employmentType, workModel, joinDate, endDate, status

AttendanceRecord

id, organizationId, employeeId, workDate, checkInAt, checkOutAt, workingMinutes, status/flags, correctedBy, correctionReason, **checkInLat**, **checkInLng**, **checkInAccuracyMeters**, **checkOutLat**, **checkOutLng**, **checkOutAccuracyMeters**, **locationSource (GPS | MANUAL | UNAVAILABLE)** v1.1

LeaveType

id, organizationId, name, paid, active

LeaveBalance

id, employeeId, leaveTypeId, period, entitlement, used, remaining/version

LeaveRequest

id, employeeId, leaveTypeId, startDate, endDate, days, reason, status, reviewedBy, reviewedAt, reviewComment

OvertimeRequest

id, employeeId, startAt, endAt, approvedMinutes, reason, status, reviewedBy, reviewedAt

SalaryProfile

id, employeeId, basicSalary, fixedAllowances, fixedDeductions, otRate/config, effectiveFrom, effectiveTo

PayrollRun

id, organizationId, periodStart, periodEnd, status, calculatedAt, approvedBy, approvedAt, paidBy, paidAt

PayrollItem

id, payrollRunId, employeeId, basicSnapshot, allowanceSnapshot, otSnapshot, bonusSnapshot, deductionSnapshot, unpaidLeaveSnapshot, grossPay, netPay, calculationMetadata

Payslip

id, payrollItemId, releasedAt, optionalDocumentRef

AuditLog

id, organizationId, actorUserId, action, resourceType, resourceId, metadata, createdAt

Appendix B. Status Machines

Employee: DRAFT -> ACTIVE -> INACTIVE / TERMINATED

Leave: PENDING -> APPROVED | REJECTED | CANCELLED; APPROVED -> CANCELLED (controlled)

Overtime: PENDING -> APPROVED | REJECTED | CANCELLED

Payroll: DRAFT -> CALCULATED -> APPROVED -> PAID

Implement transitions as explicit domain functions or service guards. Avoid arbitrary PATCH endpoints that let clients set status to any value. (GPS/location fields are record attributes, not states — they do not participate in any status machine.)

Appendix C. Example Calculations

C.1 OT Example

Approved OT = 5 hours; configured OT rate = 10,000 MMK/hour. OT earning = 50,000 MMK.

C.2 Unpaid Leave Example

Monthly basic = 1,000,000 MMK; configured divisor = 25 working days; daily rate = 40,000 MMK. One approved unpaid leave day produces a 40,000 MMK deduction.

C.3 Payroll Example

Basic 1,000,000 + allowance 100,000 + OT 50,000 = gross 1,150,000. Fixed deduction 20,000 + unpaid leave 40,000 = total deductions 60,000. Net pay = 1,090,000 MMK.

Before production use, confirm all payroll formulas, statutory obligations, rounding, and company policies with qualified HR/payroll/accounting/legal stakeholders. The MVP formulas in this handbook are software requirements examples, not legal or tax advice.

Appendix D. Developer Checklists

Before Implementing a Module

- Define actor and permission.
- Define source of truth.
- Define states and valid transitions.
- Define uniqueness/overlap rules.
- Define transaction boundary.
- Define audit requirement.
- Define error codes.
- Define tests before UI polish.

Before Merging

- Typecheck/lint/tests pass.
- Migration reviewed.
- Authorization tests included.
- Tenant-scope tests included.
- No secrets or sensitive logs.
- API docs updated.
- UI handles failure states.

Before MVP Release

- Backup/restore tested.
- Production secrets configured.
- TLS/domain configured.
- Seed/admin bootstrap documented.
- Critical E2E flow passes.
- Payroll sample independently verified.
- Audit trail reviewed.
- Known limitations documented — including that GPS location is informational-only and unverifiable (v1.1).